DAVIDLEBERKNIGHT/FOOTBAG-PLATFORM

Evalation Hardening Review



41	3	9	87
FINDINGS	CRITICAL	HIGH	HARDNESS

Overall verdict: The review found 3 critical findings, and they come first. We found 14 controls working, worth keeping as they are.

Executive summary

41 findings across 18 disciplines. The 3 critical and 9 high findings are the ones that change the risk.

BUILD QUALITY

The repository scores 87 of 100, grade A, across 18 disciplines. We found 14 controls working as intended, and the score counts them, so a change that breaks one lowers it. Performance and cost, Reliability and testing and Documentation and operations have the least risk, counting each finding by its severity.

THE RISK

Dependency advisories, Security under attack and Resilience and failure modes carry the most risk, counting each finding by its severity. Dependency advisories alone has 6 of the 41 findings, including 2 critical and 2 high. 3 findings are critical, meaning a control is missing altogether, so start there. 9 are high, where a control is in place and fails. The other 29 are medium, low or info.

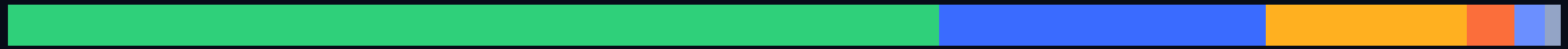
THE WORK TO CLOSE IT

Fixing the 3 critical and 9 high findings removes the serious risk, and the other 29 are lower-priority hardening. Each finding names the change that fixes it. Dependency advisories, Security under attack and Resilience and failure modes hold 17 of the 41 findings between them.

BOTTOM LINE

We read the code without running it and changed nothing in the repository. Every finding cites the file and lines it rests on.

Repository at a glance



TypeScript 60% · Python 21% · Shell 13% · Handlebars 3% · HCL 2% · CSS 1%

3,665 FILES	954,920 LINES OF CODE	9 LANGUAGES	2,914 COMMITS	41 DEPENDENCIES	144 DOCS PAGES	1,343 TESTS
3 DOCKERFILES	3 SQL / MIGRATIONS	50 INFRASTRUCTURE AS CODE	1 CI JOBS	27 HOOKS	143 SHELL SCRIPTS	38 SKILLS

Audit method

Discipline	Model	C	H	M	L	I
Security defences	Opus 5.5	0	3	0	0	0
Security under attack	Opus 5.5	1	0	0	0	0
Architecture	Opus 5.5	0	0	0	0	0
Code quality	Opus 5.5	0	0	1	2	0
Privacy and supply chain	Opus 5.5	0	1	1	0	0
Reliability and testing	Opus 5.5	0	0	0	2	0
Performance and cost	Opus 5.5	0	0	0	1	0
Compliance and governance	Opus 5.5	0	0	3	1	0
Accessibility and usability	Opus 5.5	0	0	0	0	0
Documentation and operations	Opus 5.5	0	0	0	4	0
Documentation (wiki)		0	0	0	0	0
AI and prompts		0	0	0	0	0
Algorithm correctness	Opus 5.5	0	0	1	1	0
Resilience and failure modes	Opus 5.5	0	2	5	1	0
Dependency advisories	Opus 5.5	2	2	0	2	0
API and contract design	Opus 5.5	0	1	1	0	0
Disaster recovery and durability	Opus 5.5	0	0	2	0	0
Observability and service levels	Opus 5.5	0	0	1	0	0
TOTAL		**3**	**9**	**15**	**14**	**0**

Our assessment

Dependency advisories carries the most risk

Dependency advisories holds 6 of the 41 findings, including 2 critical and 2 high, so with time for one area, start here. Security under attack and Resilience and failure modes come next.

Some controls are missing altogether

The mix is 3 critical, 9 high, 15 medium, 14 low and 0 info. A critical finding means a control is missing, so it changes what the system can promise.

Controls already holding

We found 14 controls working, places where we tested for a weakness and the control held. 2 disciplines found nothing to fix: AI and prompts and Documentation (wiki).

Second checks on the reading

We read the repository against 18 disciplines, using Opus 5.5. A second check confirmed or a scanner found every one of the 41 findings.

The work the fixes take

The work splits into 3 to do first, 9 near-term, 15 should-fix and 14 cleanup. The heaviest area, Dependency advisories, has 15% of the findings, so the work spreads across the system.

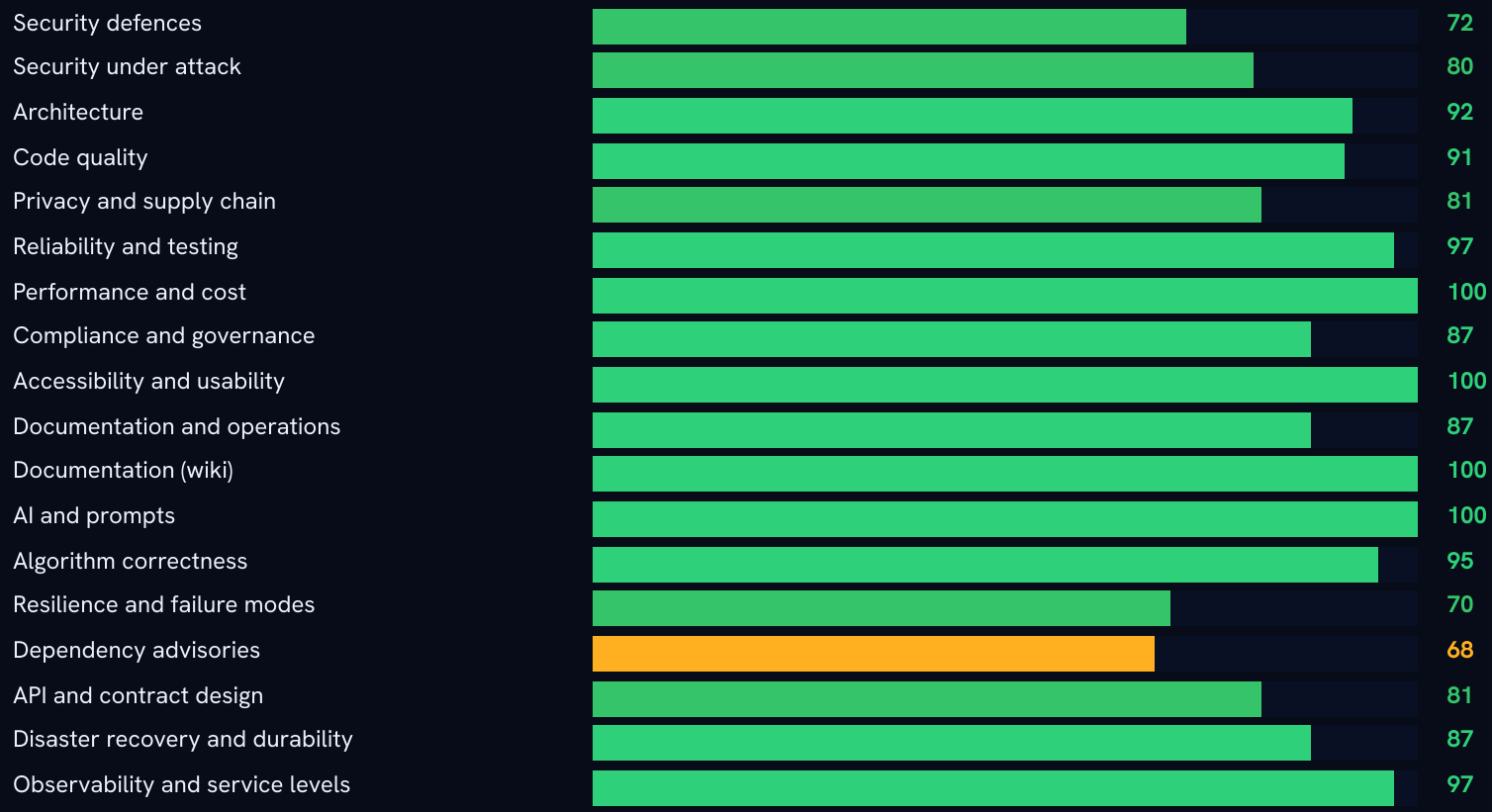
Hardness score

87

/ 100

GRADE A

We read the code without running it and changed nothing in the repository.



Critical findings (3)

XSEC-01	Lint has no no-eval or no-new-func rule, and the convention gate has no pattern for them. Today's code holds neither, yet a future change adding eval on request data would pass the build and open the server to code injection.
CVE-01	legacy_data/requirements.txt pins certifi 2026.2.25, whose bundle still trusts an emSign root with compromised intermediate keys. Scripts using it could accept a forged certificate when they fetch from the network.
CVE-02	package-lock.json pins handlebars 4.7.9, the template engine behind express-handlebars on the web server. The scan reports critical advisories for JavaScript injection, fixed in 4.7.10. Left in place, a crafted template input could run code on the server.

Strengths to keep and the roadmap

CONTROLS TO KEEP

- ✓ Role comes from the database on each request
- ✓ Test switches refuse to start outside the test runner
- ✓ Captcha outage refuses the gated forms
- ✓ Test files run in a shuffled, reproducible order
- ✓ Coverage floors fail CI when coverage drops
- ✓ Committed skipped tests fail the build

THE ORDER OF FIXES

P0 3 findings, do first: a control is missing. Concentrated in Dependency advisories (2) and Security under attack (1).

P1 9 findings, near-term: a control is in place and fails. Concentrated in Security defences (3), Dependency advisories (2), Resilience and failure modes (2), API and contract design (1) and 1 other discipline.

P2 15 findings, should-fix: weaknesses that make the system easier to break. Concentrated in Resilience and failure modes (5), Compliance and governance (3), Disaster recovery and durability (2), Algorithm correctness (1) and 4 other disciplines.

P3 14 findings, cleanup: small fixes with little risk attached. Concentrated in Documentation and operations (4), Code quality (2), Dependency advisories (2), Reliability and testing (2) and 4 other disciplines.